

Clase 288 — Seguros cibernéticos

Parte: **14 — GRC, riesgo y cumplimiento** · Fuente: (ISC)² CISSP Official Study Guide y How to Measure Anything in Cybersecurity Risk 🕒 Duración estimada: **80 min** · Nivel: **Intermedio**

Objetivo

Entender el ciberseguro como mecanismo de **transferencia de riesgo** y su papel dentro de la estrategia GRC. Al terminar sabrás qué cubre y qué excluye una póliza, cómo se calcula la prima, qué requisitos de seguridad exigen hoy las aseguradoras (MFA, EDR, backups), cómo cuantificar la cobertura adecuada y por qué el seguro complementa —pero nunca sustituye— a los controles.

Resultados de aprendizaje

Al finalizar, el alumno podrá:

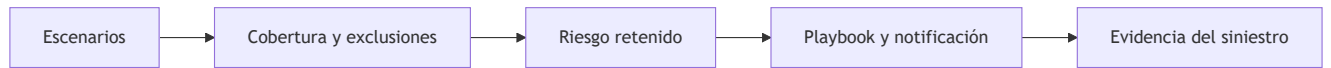
- 1. **Ubicar** el seguro en las opciones de tratamiento de riesgo (transferir).
- 2. **Interpretar** coberturas, exclusiones, límites y franquicias de una póliza.
- 3. **Identificar** los requisitos de seguridad que exigen las aseguradoras.
- 4. **Cuantificar** la cobertura adecuada a partir del análisis de riesgo (ALE).
- 5. **Preparar** la evidencia para un cuestionario de suscripción (underwriting).

Temas

#	Tema	Por qué importa
1	Transferencia de riesgo	Una de las 4 respuestas al riesgo
2	Coberturas de primera y tercera parte	Qué gastos cubre
3	Exclusiones típicas	Dónde NO te cubre
4	Límites, sublímites y franquicia	Cuánto pagará realmente
5	Requisitos de suscripción	MFA, EDR, backups, formación
6	Cálculo de la cobertura adecuada	Del ALE a la suma asegurada
7	El seguro no sustituye controles	Riesgo moral y denegación de siniestro

Explicación en profundidad

El seguro transfiere consecuencias financieras definidas; no transfiere responsabilidad operativa ni todo riesgo. Cobertura depende de definiciones, límites, retención, exclusiones, sublímites, notificación y obligaciones del asegurado. La póliza se integra con respuesta y continuidad antes del incidente.



Caso razonado

Una organización contrata ransomware, pero no prueba restauración y omite el plazo de notificación. Seguro y resiliencia resuelven problemas distintos.



Glosario operativo

Término	Definición
Retención/deducible	Parte inicial de pérdida asumida por asegurado.
Sublímite	Límite específico dentro de la cobertura.
Exclusión	Circunstancia que la póliza no cubre.



Criterio de dominio

Existe dominio cuando el alumno compara escenarios con texto contractual, identifica riesgo retenido y conecta notificación con IR.



Definiciones y características

- **Transferencia de riesgo:** trasladar el impacto financiero a un tercero (aseguradora). *Clave:* transfiere el coste, no la responsabilidad.
- **Cobertura de primera parte:** gastos propios (recuperación, forense, notificación, extorsión, lucro cesante). *Clave:* te paga a ti.
- **Cobertura de tercera parte:** reclamaciones de terceros (clientes, reguladores) por la brecha. *Clave:* te defiende frente a otros.
- **Exclusión:** supuesto no cubierto (actos de guerra, negligencia grave, controles falsos declarados). *Clave:* leer siempre la letra pequeña.
- **Límite y sublímite:** máximo total y máximo por tipo de cobertura. *Clave:* un sublímite bajo de ransomware puede dejarte corto.
- **Franquicia (deducible):** importe que asumes antes de que pague el seguro. *Clave:* a mayor franquicia, menor prima.
- **Underwriting:** proceso de evaluación de tu riesgo para fijar prima y condiciones. *Clave:* exige evidencia de controles.



Herramientas y preparación

- El resultado de tu análisis de riesgo cuantitativo (ALE) de la clase 277.
- Un cuestionario de suscripción de ciberseguro de referencia (los publican corredores y aseguradoras).
- Referencia conceptual: informes de mercado de ciberseguro (Marsh, Munich Re) y las guías de ENISA/CISA sobre transferencia de riesgo.
- Hoja de cálculo para comparar coberturas y calcular la suma asegurada.



Laboratorio guiado (ejercicio aplicado)

Vas a evaluar la contratación de un ciberseguro para "Ferretería del Sur S.A.".

1. **Punto de partida:** recupera el ALE de tus escenarios de la clase 277 (ransomware 15.000 €, brecha de datos, caída). Estima además el peor caso plausible (P90) de una brecha grave con multa GDPR y notificación (p. ej. 400.000 €).
2. **Decisión de tratamiento:** justifica qué parte del riesgo mitigas con controles, cuál aceptas y cuál transfieres al seguro.
3. **Coberturas necesarias:** lista las coberturas que pedirías (forense, restauración, notificación a afectados, defensa legal, sanciones asegurables, extorsión/ransomware, lucro cesante).
4. **Cuestionario de suscripción:** responde (para la empresa ficticia) las preguntas típicas: ¿MFA en accesos remotos y privilegiados? ¿EDR desplegado? ¿backups offline probados? ¿plan de respuesta a incidentes? ¿formación de phishing? Marca cuáles cumples y cuáles no.
5. **Brechas que suben la prima:** identifica 3 carencias del cuestionario y qué control implementarías para bajar la prima o poder asegurarte.
6. **Análisis de exclusiones:** revisa una lista de exclusiones típicas (guerra, controles declarados inexistentes, incumplimiento de parches conocidos) y explica el riesgo de declarar controles que no operas.
7. **Suma asegurada:** propón un límite y una franquicia coherentes con tu P90 y tu capacidad de asumir la franquicia. Compara prima estimada vs. riesgo transferido.

Ejercicios

1. Clasifica en primera o tercera parte: honorarios de abogados por demanda de clientes; coste del forense; multa de la autoridad de protección de datos.
2. Explica por qué el seguro transfiere el coste pero no la responsabilidad legal.
3. Un asegurado declaró tener MFA pero no lo tenía; sufre ransomware. ¿Qué puede pasar con el siniestro?
4. Dado un ALE y un P90, argumenta qué límite de cobertura pedirías.
5. Enumera 4 requisitos de suscripción habituales y por qué las aseguradoras los exigen.
6. Explica el "riesgo moral" de confiar solo en el seguro y descuidar los controles.

Reto verificable

Entrega un **dossier de evaluación de ciberseguro** con: decisión de tratamiento (mitigar/aceptar/transferir) justificada por el ALE, lista de coberturas requeridas, cuestionario de suscripción respondido con brechas identificadas, análisis de exclusiones y una propuesta de límite y franquicia razonada.

Criterio de aceptación: la suma asegurada se justifica con el análisis de riesgo (ALE/P90), se identifican al menos 3 controles que mejorarían la asegurabilidad, y el dossier deja claro que el seguro complementa — no reemplaza— los controles.

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
"Con el seguro no necesito invertir en controles"	Riesgo moral; las aseguradoras exigen controles y deniegan sin ellos
Declarar controles que no se tienen	Anula la cobertura; declara solo lo que operas y puedes evidenciar
Ignorar los sublímites	Un sublímite bajo de ransomware deja la mayor pérdida descubierta
No leer las exclusiones	Sorpresa en el siniestro; revisa guerra, negligencia, parches
Suma asegurada al azar	Deriva del ALE y del peor caso plausible (P90)

Preguntas frecuentes

 **¿El ciberseguro sustituye a tener buena seguridad?** No. Es la cuarta opción de tratamiento (transferir), para el riesgo residual que no puedes mitigar económicamente. Sin controles, ni te aseguran ni te pagan.

 **¿Cubre las multas de GDPR?** Depende de la póliza y la jurisdicción; algunas sanciones no son asegurables por ley. Revisa la cobertura de "sanciones regulatorias asegurables".

 **¿Por qué me piden MFA y EDR para asegurarme?** Porque reducen drásticamente la frecuencia y el impacto de los siniestros. Se han vuelto requisitos mínimos de suscripción.

 **¿Qué pasa si mentí en el cuestionario?** La aseguradora puede denegar el siniestro por declaración inexacta. La honestidad en el underwriting es condición para cobrar.

Referencias

- Hubbard & Seiersen — How to Measure Anything in Cybersecurity Risk (transferencia y cuantificación).
- ENISA — Cyber Insurance: Recent Advances and Good Practices. <https://www.enisa.europa.eu/>
- CISA — Cyber Insurance guidance. <https://www.cisa.gov/>
- Marsh — Cyber Insurance market reports. <https://www.marsh.com/>
- (ISC)² CISSP Official Study Guide, dominio 1 (Tratamiento del riesgo).

Material descargable

-  [Guía en PDF](#) — versión imprimible de esta clase.
-  [Presentación \(PPTX\)](#) — deck para proyectar en clase.

Clase anterior

Clase 287 — Métricas de seguridad: KPIs y KRIs

Siguiente clase

Clase 289 — Privacidad y protección de datos